Vulnerability Assessment Report

ACME Corp (demo)

Generated 2026-10-25 19:39 UTC by examples

Scope: 8 network asset(s), host audit of web-prod-01, traffic capture 'demo:sensor-eth0'

RISK SCORE	SECURITY POSTURE	OPEN FINDINGS	CRITICAL	HIGH	ASSETS	COMPLIANCE	NETWORK HEALTH
96/100	**4/100**	**26**	**10**	**8**	**8**	**9%**	**0/100**

Summary

The assessment identified 26 open finding(s): 10 critical, 8 high, 6 medium and 2 low. The aggregated risk score is 96/100, which corresponds to a critical level of risk. Critical findings must be remediated immediately (P1, 24-72 hours).

Severity matrix

Category	Critical	High	Medium	Low	Informational	Total
exposure	1	2	3	2		8
vulnerability	9	6	3			18
Total	**10**	**8**	**6**	**2**	**0**	**26**

Findings

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2021-42013

Identifier	CVE-2021-42013 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Incomplete fix for CVE-2021-41773: path traversal and remote code execution in Apache HTTP Server 2.4.49 and 2.4.50. A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (versions 2.4.49, 2.4.50).
Recommendation	Upgrade Apache HTTP Server to 2.4.51 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-42013

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2022-22720

Identifier	CVE-2022-22720 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Apache HTTP Server 2.4.52 and earlier fails to close the inbound connection when errors are encountered discarding the request body, exposing the server to HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (<= 2.4.52).
Recommendation	Upgrade Apache HTTP Server to 2.4.53 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2022-22720

CRITICAL Apache HTTP Server 2.4.49 affected by CVE-2023-25690

Identifier	CVE-2023-25690 | CVSS 9.8 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Some mod_proxy configurations on Apache HTTP Server 2.4.0 through 2.4.55 allow HTTP request smuggling.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (>= 2.4.0 and <= 2.4.55).
Recommendation	Upgrade Apache HTTP Server to 2.4.56 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-25690

CRITICAL OpenSSH 8.9p1 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL vsftpd 2.3.4 affected by CVE-2011-2523

Identifier	CVE-2011-2523 | CVSS 9.8 | confidence high
Asset	10.10.0.11:21 | vulnerability | vulnerability_analyzer
Description	vsftpd 2.3.4 downloaded between 2011-06-30 and 2011-07-03 contains a backdoor which opens a shell on port 6200/tcp. A public exploit is available.
Evidence	21/tcp banner 'vsftpd 2.3.4' matches affected range (versions 2.3.4).
Recommendation	Upgrade vsftpd to 2.3.5 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2011-2523

CRITICAL Samba 4.5.9 affected by CVE-2017-7494

Identifier	CVE-2017-7494 | CVSS 9.8 | confidence high
Asset	10.10.0.11:445 | vulnerability | vulnerability_analyzer
Description	SambaCry: a malicious client can upload a shared library to a writable share and cause the server to load and execute it (remote code execution). A public exploit is available.
Evidence	445/tcp banner 'Samba smbd 4.5.9 workgroup: CORP' matches affected range (>= 4.5.0 and < 4.5.10).
Recommendation	Upgrade Samba to 4.6.4 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2017-7494

CRITICAL OpenSSH 7.4 affected by CVE-2023-38408

Identifier	CVE-2023-38408 | CVSS 9.8 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	The PKCS#11 feature in ssh-agent has an insufficiently trustworthy search path, leading to remote code execution if an agent is forwarded to an attacker-controlled system.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (< 9.3p2).
Recommendation	Upgrade OpenSSH to 9.3p2 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-38408

CRITICAL Exim 4.89 affected by CVE-2019-10149

Identifier	CVE-2019-10149 | CVSS 9.8 | confidence high
Asset	10.10.0.12:25 | vulnerability | vulnerability_analyzer
Description	Improper validation of recipient addresses in deliver_message() in Exim 4.87 to 4.91 allows remote command execution ("Return of the WIZard"). A public exploit is available.
Evidence	25/tcp banner 'Exim smtpd 4.89' matches affected range (>= 4.87 and <= 4.91).
Recommendation	Upgrade Exim to 4.92 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2019-10149

CRITICAL Apache Tomcat 9.0.30 affected by CVE-2020-1938

Identifier	CVE-2020-1938 | CVSS 9.8 | confidence high
Asset	10.10.0.13:8080 | vulnerability | vulnerability_analyzer
Description	Ghostcat: the AJP connector trusts incoming connections by default, allowing file read/inclusion (and RCE when uploads are possible) in Apache Tomcat. A public exploit is available.
Evidence	8080/tcp banner 'Apache Tomcat 9.0.30' matches affected range (>= 9.0.0.M1 and < 9.0.31).
Recommendation	Upgrade Apache Tomcat to 9.0.31 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2020-1938

CRITICAL Docker Engine API exposed without TLS

Identifier	EXP-DOCKER | confidence high
Asset	10.10.0.21:2375 | exposure | vulnerability_analyzer
Description	Docker Engine API exposed without TLS on 10.10.0.21:2375/tcp.
Evidence	2375/tcp docker Docker 20.10.7
Recommendation	Never expose the Docker socket over TCP without mutual TLS; bind to a unix socket only.

HIGH OpenSSH 8.9p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

HIGH OpenSSH 9.7p1 affected by CVE-2024-6387

Identifier	CVE-2024-6387 | CVSS 8.1 | confidence high
Asset	10.10.0.12:22 | vulnerability | vulnerability_analyzer
Description	regreSSHion: a signal handler race condition in sshd's SIGALRM handling (LoginGraceTime) can allow unauthenticated remote code execution as root on glibc-based Linux systems.
Evidence	22/tcp banner 'OpenSSH 9.7p1 protocol 2.0' matches affected range (>= 8.5p1 and < 9.8p1).
Recommendation	Upgrade OpenSSH to 9.8p1 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2024-6387 | https://www.qualys.com/2024/07/01/cve-2024-6387/regresshion.txt

HIGH nginx 1.18.0 affected by CVE-2021-23017

Identifier	CVE-2021-23017 | CVSS 7.7 | confidence medium
Asset	10.10.0.14:80 | vulnerability | vulnerability_analyzer
Description	A one-byte memory overwrite in the nginx DNS resolver may allow an attacker able to forge UDP packets from the DNS server to crash the worker process or have other impact.
Evidence	80/tcp banner 'nginx 1.18.0 Ubuntu' matches affected range (>= 0.6.18 and < 1.20.1).
Recommendation	Upgrade nginx to 1.20.1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-23017 | https://nginx.org/en/security_advisories.html

HIGH nginx 1.18.0 affected by CVE-2021-23017

Identifier	CVE-2021-23017 | CVSS 7.7 | confidence medium
Asset	10.10.0.14:443 | vulnerability | vulnerability_analyzer
Description	A one-byte memory overwrite in the nginx DNS resolver may allow an attacker able to forge UDP packets from the DNS server to crash the worker process or have other impact.
Evidence	443/tcp banner 'nginx 1.18.0 Ubuntu' matches affected range (>= 0.6.18 and < 1.20.1).
Recommendation	Upgrade nginx to 1.20.1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-23017 | https://nginx.org/en/security_advisories.html

HIGH OpenSSL 1.0.1f affected by CVE-2014-0160

Identifier	CVE-2014-0160 | CVSS 7.5 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Heartbleed: the TLS heartbeat extension in OpenSSL 1.0.1 through 1.0.1f does not properly handle heartbeat requests, disclosing process memory (private keys, credentials). A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (>= 1.0.1 and <= 1.0.1f).
Recommendation	Upgrade OpenSSL to 1.0.1g or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2014-0160 | https://heartbleed.com/

HIGH Apache HTTP Server 2.4.49 affected by CVE-2021-41773

Identifier	CVE-2021-41773 | CVSS 7.5 | confidence high
Asset	10.10.0.10:80 | vulnerability | vulnerability_analyzer
Description	Path traversal and file disclosure in Apache HTTP Server 2.4.49 via a flaw in path normalization; can lead to remote code execution when CGI is enabled. A public exploit is available.
Evidence	80/tcp banner 'Apache httpd 2.4.49 (Unix) OpenSSL/1.0.1f' matches affected range (versions 2.4.49).
Recommendation	Upgrade Apache HTTP Server to 2.4.51 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2021-41773 | https://httpd.apache.org/security/vulnerabilities_24.html

HIGH

Redis exposed to the network

Identifier	EXP-REDIS | confidence high
Asset	10.10.0.13:6379 | exposure | vulnerability_analyzer
Description	Redis exposed to the network on 10.10.0.13:6379/tcp.
Evidence	6379/tcp redis Redis key-value store 5.0.7
Recommendation	Bind Redis to 127.0.0.1, enable protected-mode and ACL authentication.

HIGH

Telnet service exposed (cleartext credentials)

Identifier	EXP-TELNET | confidence high
Asset	10.10.0.20:23 | exposure | vulnerability_analyzer
Description	Telnet service exposed (cleartext credentials) on 10.10.0.20:23/tcp.
Evidence	23/tcp telnet Linux telnetd
Recommendation	Disable Telnet and use SSH with key-based authentication.

MEDIUM

OpenSSH 8.9p1 affected by CVE-2023-48795

Identifier	CVE-2023-48795 | CVSS 5.9 | confidence medium
Asset	10.10.0.10:22 | vulnerability | vulnerability_analyzer
Description	Terrapin: the SSH transport protocol with certain OpenSSH extensions allows remote attackers to bypass integrity checks (prefix truncation), downgrading connection security. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 8.9p1 Ubuntu 3ubuntu0.6 Ubuntu Linux; protocol 2.0' matches affected range (< 9.6p1).
Recommendation	Upgrade OpenSSH to 9.6p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-48795 | https://terrapin-attack.com/

MEDIUM

OpenSSH 7.4 affected by CVE-2023-48795

Identifier	CVE-2023-48795 | CVSS 5.9 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	Terrapin: the SSH transport protocol with certain OpenSSH extensions allows remote attackers to bypass integrity checks (prefix truncation), downgrading connection security. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (< 9.6p1).
Recommendation	Upgrade OpenSSH to 9.6p1 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2023-48795 | https://terrapin-attack.com/

MEDIUM

OpenSSH 7.4 affected by CVE-2018-15473

Identifier	CVE-2018-15473 | CVSS 5.3 | confidence high
Asset	10.10.0.11:22 | vulnerability | vulnerability_analyzer
Description	OpenSSH through 7.7 is prone to a user enumeration vulnerability due to not delaying bailout for an invalid authenticating user. A public exploit is available.
Evidence	22/tcp banner 'OpenSSH 7.4 protocol 2.0' matches affected range (<= 7.7).
Recommendation	Upgrade OpenSSH to 7.8 or later.
References	https://nvd.nist.gov/vuln/detail/CVE-2018-15473

MEDIUM

Database service reachable over the network

Identifier	EXP-DATABASE | confidence high
Asset	10.10.0.10:3306 | exposure | vulnerability_analyzer
Description	Database service reachable over the network on 10.10.0.10:3306/tcp.
Evidence	3306/tcp mysql MySQL 8.0.36
Recommendation	Restrict database ports to application servers via firewall rules and require TLS.

MEDIUM

FTP service exposed (cleartext credentials)

Identifier	EXP-FTP | confidence high
Asset	10.10.0.11:21 | exposure | vulnerability_analyzer
Description	FTP service exposed (cleartext credentials) on 10.10.0.11:21/tcp.
Evidence	21/tcp ftp vsftpd 2.3.4
Recommendation	Replace FTP with SFTP/FTPS; if FTP is required, disable anonymous access.

MEDIUM

SMB/NetBIOS file sharing exposed

Identifier	EXP-SMB | confidence high
Asset	10.10.0.11:445 | exposure | vulnerability_analyzer
Description	SMB/NetBIOS file sharing exposed on 10.10.0.11:445/tcp.
Evidence	445/tcp netbios-ssn Samba smbd 4.5.9
Recommendation	Disable SMBv1, require SMB signing and restrict SMB to trusted segments.

LOW

Web service without HTTPS

Identifier	EXP-HTTP-NOTLS | confidence high
Asset	10.10.0.10:80 | exposure | vulnerability_analyzer
Description	HTTP on port 80 and no HTTPS listener detected on the host.
Evidence	80/tcp Apache httpd 2.4.49
Recommendation	Enable HTTPS with a valid certificate and redirect HTTP to HTTPS (HSTS).

LOW

Web service without HTTPS

Identifier	EXP-HTTP-NOTLS | confidence high
Asset	10.10.0.13:8080 | exposure | vulnerability_analyzer
Description	HTTP on port 8080 and no HTTPS listener detected on the host.
Evidence	8080/tcp Apache Tomcat 9.0.30
Recommendation	Enable HTTPS with a valid certificate and redirect HTTP to HTTPS (HSTS).

Recommendations

1. Upgrade Apache HTTP Server to 2.4.51 or later.
2. Upgrade Apache HTTP Server to 2.4.53 or later.
3. Upgrade Apache HTTP Server to 2.4.56 or later.

4. Upgrade OpenSSH to 9.3p2 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.

5. Upgrade vsftpd to 2.3.5 or later.

6. Upgrade Samba to 4.6.4 or later.

7. Upgrade OpenSSH to 9.3p2 or later.

8. Upgrade Exim to 4.92 or later.

9. Upgrade Apache Tomcat to 9.0.31 or later.

10. Never expose the Docker socket over TCP without mutual TLS; bind to a unix socket only.

11. Upgrade OpenSSH to 9.8p1 or later. Distribution package detected: verify with the distro security tracker, the fix may be backported without a version change.

12. Upgrade OpenSSH to 9.8p1 or later.

Remediation priorities

Priority	Severity	Target	Count	Examples
P1 Immediate	CRITICAL	Within 24-72 hours	10	Apache HTTP Server 2.4.49 affected by CVE-2021-42013 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2022-22720 (10.10.0.10); Apache HTTP Server 2.4.49 affected by CVE-2023-25690 (10.10.0.10); OpenSSH 8.9p1 affected by CVE-2023-38408 (10.10.0.10); vsftpd 2.3.4 affected by CVE-2011-2523 (10.10.0.11)
P2 Urgent	HIGH	Within 7 days	8	OpenSSH 8.9p1 affected by CVE-2024-6387 (10.10.0.10); OpenSSH 9.7p1 affected by CVE-2024-6387 (10.10.0.12); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); nginx 1.18.0 affected by CVE-2021-23017 (10.10.0.14); OpenSSL 1.0.1f affected by CVE-2014-0160 (10.10.0.10)
P3 Planned	MEDIUM	Within 30 days	6	OpenSSH 8.9p1 affected by CVE-2023-48795 (10.10.0.10); OpenSSH 7.4 affected by CVE-2023-48795 (10.10.0.11); OpenSSH 7.4 affected by CVE-2018-15473 (10.10.0.11); Database service reachable over the network (10.10.0.10); FTP service exposed (cleartext credentials) (10.10.0.11)
P4 Routine	LOW	Within 90 days	2	Web service without HTTPS (10.10.0.10); Web service without HTTPS (10.10.0.13)

Asset inventory

IP	Hostname	Open services	Risk score
10.10.0.10	web-prod-01.corp.example	22/tcp OpenSSH 8.9p1 Ubuntu 3ubuntu0.6, 80/tcp Apache httpd 2.4.49, 3306/tcp MySQL 8.0.36	73
10.10.0.11	files-01.corp.example	21/tcp vsftpd 2.3.4, 22/tcp OpenSSH 7.4, 445/tcp Samba smbd 4.5.9	57
10.10.0.12	mail-01.corp.example	22/tcp OpenSSH 9.7p1, 25/tcp Exim smtpd 4.89	27
10.10.0.13	app-01.corp.example	6379/tcp Redis key-value store 5.0.7, 8009/tcp Apache Jserv, 8080/tcp Apache Tomcat 9.0.30	54
10.10.0.14	proxy-01.corp.example	80/tcp nginx 1.18.0, 443/tcp nginx 1.18.0	21
10.10.0.20	core-sw-legacy.corp.example	23/tcp Linux telnetd	11
10.10.0.21	dev-docker-01.corp.example	22/tcp OpenSSH 9.8p1, 2375/tcp Docker 20.10.7	18
10.10.0.30	backup-01.corp.example	22/tcp OpenSSH 9.8p1	0

Produced by CyberShield 1.0.0 for authorised defensive use only. Automated findings should be validated by a qualified analyst before remediation decisions.